

AIGP

AI Governance Professional

Certification Study Guide - Quick Notes

Arjun Tarakesh

Restructured for study: domain recaps, applied worked examples for an RBI-regulated NBFC (low AI security maturity), and a full NIST AI RMF control table.

Table of Contents

(Right-click the list below and choose "Update Field" if page numbers do not appear automatically.)

Table of Contents	2
Domain 1: Understanding the Foundations of Artificial Intelligence	3
1.1 Basic Elements of AI and ML	3
1.2 Differences Among Types of AI Systems	5
1.3 The AI Technology Stack	7
1.4 History of AI and the Evolution of Data Science	8
Domain 2: Understanding AI Impacts and Responsible AI Principles	10
2.1 Core Risks and Harms Posed by AI Systems	10
2.2 Characteristics of Trustworthy AI Systems	11
2.3 Existing and Emerging Ethical Guidance on AI	11
Domain 3: Understanding How Current Laws Apply to AI Systems	15
3.1 Existing Laws That Interact With AI Use	15
3.2 Key GDPR Intersections	16
3.3 Liability Reform	17
Domain 4: Understanding the Existing and Emerging AI Laws and Standards	19
4.1 Requirements of the EU AI Act	19
4.2 Other Emerging Global Laws	20
4.3 Major Risk Management Frameworks and Standards	21
Domain 5: Understanding the AI Development Life Cycle	24
5.1 Planning Phase	24
5.2 Design Phase	24
5.3 Development Phase	24
5.4 Implementation Phase	24
Domain 6: Implementing Responsible AI Governance and Risk Management	26
6.1 Interoperability of AI Risk Management With Other Operational Risk Strategies	26
6.2 Integrating AI Governance Principles Into the Company	26
6.3 Establishing an AI Governance Infrastructure	26
6.4 Map, Plan, and Scope the AI Project	26
6.5 Test and Validate the AI System During Development	27
6.6 Manage and Monitor AI Systems After Deployment	27
Domain 7: Contemplating Ongoing Issues and Concerns	29
7.1 Legal Issues	29
7.2 User Concerns	29
7.3 AI Auditing and Accountability Issues	30
7.4 Other Notes	30
NIST AI Risk Management Framework (AI RMF 1.0) — Summary	32
Overview	32
Seven Characteristics of Trustworthy AI	32
The Four Core Functions	32
How AI Risk Differs From Traditional Software Risk	32

Total Control Count	33
Full Control Listing — GOVERN Function	34
Full Control Listing — MAP Function	36
Full Control Listing — MEASURE Function	38
Full Control Listing — MANAGE Function	40

Domain 1: Understanding the Foundations of Artificial Intelligence

1.1 Basic Elements of AI and ML

Common elements of AI/ML definitions under new and emerging law

- **1. Technology** — an engineered or machine-based system; or logic, knowledge, or learning algorithm.

AI is “An engineered or machine-based system that can, for a given set of objectives, generate outputs such as predictions, recommendations, or decisions influencing real or virtual environments. AI systems are designed to operate with varying levels of autonomy.” — NIST

“Machine learning (ML) is a branch of artificial intelligence (AI) and computer science that focuses on the using data and algorithms to enable AI to imitate the way that humans learn, gradually improving its accuracy.”

- Knowledge-based systems capture the knowledge of human experts to support decision-making — e.g., an expert system relies on human expertise.
- **2. Automation** — elements of varying levels.
 - Automation is any technology that reduces human labor, especially for predictable or routine tasks.
 - AI simulates human intelligence with machines that can learn, reason, and act independently.
 - Automation is about setting up machines to follow commands; AI is about setting up machines to mimic humans and think for themselves.
- **3. Role of humans** — define objectives or provide data.
 - AI is meant to enhance human work, making it more efficient and higher quality.
 - Humans may define the objective for an AI, or provide the data to train it for a specific objective.
 - “Humans decide which datasets are discoverable, linked and analyzed.”
 - Humans determine whether data, algorithms, methods, code, and people — operating within specified technical, operational, and legal controls — are reliable and safe to produce appropriate outcomes.
- **4. Output** — content, predictions, recommendations, or decisions.
 - **Predictive AI** — offers predictions that inform recommendations or decisions.
 - **Generative AI** — generates new content, such as text, images, and video.

Generative AI vs Predictive AI

Parameter	Generative AI	Predictive AI
Objective	Generates new, original content or data	Predicts and analyzes existing patterns or outcomes

Parameter	Generative AI	Predictive AI
Function	Creates new information or content	Makes predictions based on existing data
Training data	Requires diverse and comprehensive data	Requires historical data for learning and prediction
Examples	Text generation, image synthesis	Forecasting, classification, regression
Learning process	Learns patterns and relationships in data	Learns from historical data to make predictions
Use cases	Creative tasks, content creation	Business analytics, financial forecasting
Challenges	May lack specificity in output	Limited to existing patterns, may miss novel scenarios
Training complexity	Generally more complex and resource-intensive	Requires less complex training vs. generative models
Creativity	Creative — produces things that never existed before	Lacks the element of content creation
Algorithms	Complex algorithms and deep learning	Statistical algorithms and machine learning

AI systems as socio-technical systems

A socio-technical system is one in which social and technical elements are intertwined. AI systems are socio-technical because they are not just technical tools — they have a social impact on the people who use them and are affected by them.

Cross-disciplinary collaboration

Ensuring UX, anthropology, sociology, and linguistics experts are involved and valued “allows complex problems to be solved that a single discipline alone could not handle.”

OECD Framework for the Classification of AI Systems

The Framework (oecd.ai/en/classification) is used to:

- **Promote a common understanding of AI** — identify features of AI systems to help tailor policies and develop metrics for subjective criteria (e.g., well-being impact).
- **Inform registries or inventories** — describe systems and characteristics in inventories/registries of algorithms or automated decision systems.
- **Support sector-specific frameworks** — provide a basis for domain-specific catalogs (healthcare, finance).

- **Support risk assessment** — help de-risk and mitigate, and build a common framework for reporting AI incidents.
- **Support risk management** — inform mitigation, compliance, and enforcement along the AI lifecycle, including corporate governance.

The Framework classifies AI systems along five dimensions:

- **People & Planet** — considers the potential of AI to promote human-centric, trustworthy outcomes; identifies affected individuals/groups, optionality, and impact on human rights, environment, well-being, society, and work.
- **Economic Context** — the sector, business function/model, criticality, deployment scale, and technological maturity of the applied AI system.
- **Data & Input** — provenance, collection method, structure/format, and properties of data used to train (“in the lab”) and to run (“in the field”) the system.
- **AI Model** — the computational representation of the environment; how the model is built (expert knowledge, ML, or both) and used.
- **Task & Output** — the tasks performed (personalisation, recognition, forecasting, goal-driven optimisation), outputs, resulting actions, action autonomy, and evaluation methods.

Use cases and benefits of AI

Recognition, event detection, forecasting, personalization, interaction support, goal-driven optimization, and recommendation.

Generative AI augments (not replaces) the work of writers, designers, artists, and musicians. Common generative use cases:

- **Text** — draft business letters, articles, and annual reports.
- **Images** — realistic images from text prompts, new scenes, simulated paintings.
- **Video** — compile video content automatically from text and existing images.
- **Music** — compile new compositions by analyzing a music catalog.
- **Product design** — generate possible design changes from prior product versions.
- **Personalization** — tailored recommendations and experiences.

Predictive AI use cases across industries:

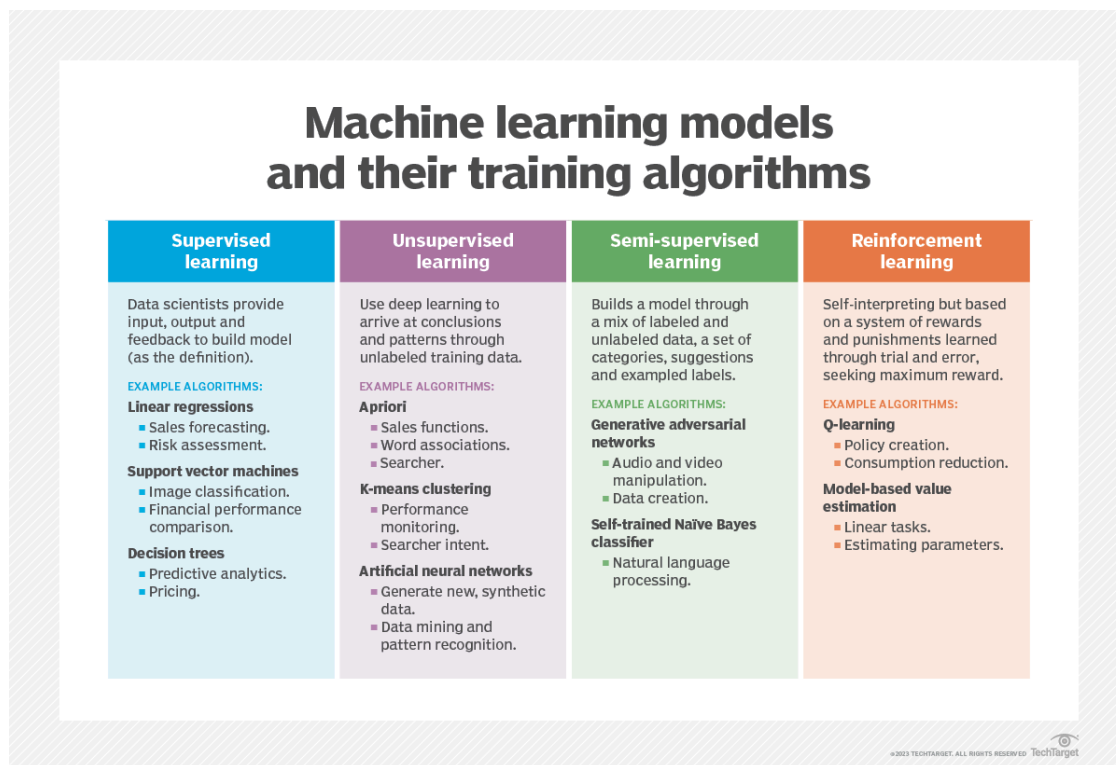
- **Financial services** — enhanced forecasting by correlating financial and forward-looking business data.
- **Fraud detection** — spotting anomalous behavior (e.g., unusual device, location, or IP address).
- **Healthcare** — predicting disease outbreaks, identifying higher-risk patients, spotting successful treatments.
- **Marketing** — defining the most appropriate channels and messages for campaigns.

1.2 Differences Among Types of AI Systems

Strong/Broad vs. Weak/Narrow AI

Aspect	Weak AI (Narrow AI)	Strong AI (AGI / Deep AI)
Scope	Limited to a singular or limited domain; mimics human thought processes	Comprehensive intellect capable of learning and applying ability to solve any problem
Rule-following	Adheres to and is constrained by its rules	Understands, works, and reasons differently from humans in certain situations
Consciousness	No consciousness or awareness of its own	Possesses creativity, common sense, and logic like humans
Goal	Complete a task with creative, accurate solutions	Solve problems at a faster pace
Examples	Alexa, Siri, Google Assistant, Google Maps routing, ChatGPT, spam filters, image recognition	No real examples exist (hypothetical); fictional: Wall-E, Big Hero 6
Useful for	—	Cybersecurity, high-intellect robots, IoT integration, language translation machines

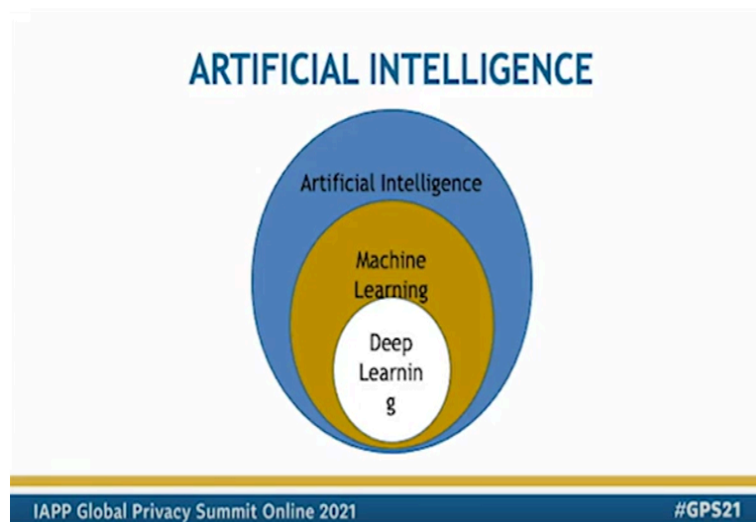
Machine learning training methods



Machine learning models and their training algorithms (source)

- **Supervised learning** — works with pre-labeled data. Classification and regression are the most common types.
 - Classification algorithms decide the category of an entity, object, or event (e.g., yes/no, cat/dog/mouse). Popular algorithms: decision trees, logistic regression, random forest, support vector machines.
 - Regression algorithms identify relationships within multiple variables (e.g., sales vs. price, temperature, day of week). Popular algorithms: linear, multivariate, decision tree, and lasso regression.
- **Unsupervised learning** — automates finding patterns in a dataset. Clustering and dimensional reduction are the two common types.
 - Clustering algorithms group similar sets of data to identify patterns within each group.
 - Dimension reduction algorithms compact multiple variables efficiently for a specific problem.
- **Semi-supervised learning** — uses unsupervised algorithms to automatically generate labels for data that supervised techniques then consume.
- **Reinforcement learning** — used to improve models after deployment; most common algorithms use various neural networks.

Deep learning, generative AI, multi-modal models, and transformer models



AI, Machine Learning, and Deep Learning (IAPP Global Privacy Summit 2021)

- **Deep learning** — a type of ML/AI that imitates how humans gain knowledge; performs classification and pattern recognition on photos, text, audio, etc.; enables learning by example (e.g., digital assistants, fraud detection, facial recognition); creates predictive models from large amounts of unlabeled, unstructured data.
- **Generative AI** — generates content resembling existing data (a type of deep learning), newer than predictive AI which recognizes patterns across time.
- **Multi-modal models** — a subset of deep learning that fuses and analyzes data from multiple modalities (text, images, video, audio, sensor data) to create a more complete representation of data.

- Two primary benefits: (1) multiple sensors observing the same data yield more robust predictions; (2) fusing sensors captures complementary information individual modalities may miss.
- Three architecture parts: unimodal encoders (per modality), a fusion network (combines features), and a classifier (accepts fused data to predict).
- **Transformer models** — deep learning models used for NLP; translate text/speech near-real-time by processing tokens through layers with self-attention and feedforward networks; trained via supervised learning minimizing a loss function.

Natural language processing

The input is a block of text (written or converted from speech), and the output is some desired characteristic of the text, such as its purpose (search query, command, review) and meaning or tone (positive, negative, angry, biased).

Robotics vs. Robotic Process Automation (RPA)

- **Robotics** — machines that can see, sense, actuate, and, with varying autonomy, make decisions.
- **RPA** — a software robot that mimics human actions, whereas AI is the simulation of human intelligence using computer software.

1.3 The AI Technology Stack

The AI stack is a layered framework — data ingestion, data storage, data processing, ML algorithms, APIs, and user interfaces — enabling modularity, scalability, and troubleshooting (unlike a monolithic architecture).

The Generative AI tech stack is structured in three layers — Applications, Model, and Infrastructure — comprising infrastructure, ML models (GANs, transformers), programming languages, and deployment tools.

Platforms, applications, and model types

- **Platforms and applications** — frameworks such as LangChain, Fixie, Microsoft Semantic Kernel, and Google Vertex AI equip engineers to build applications for autonomous content creation, semantic search, and agent-driven task execution.
- **Foundation Models (FMs)** — large-scale, pre-trained models serving as the cognitive layer enabling complex decision-making and reasoning.
- **Closed-source Foundation Models** — obscure/protect the model, training-data provenance, and code; typically faster, usable via cloud services.
- **Open-source Foundation Models** — openly share the model, data provenance, and code; enable greater scrutiny and often improve explainability and security.

Comparing open and closed AI

	Open AI	Closed AI
MODELS	Publicly available, architecture shared	Kept private, protects proprietary information
DATA	Transparent training, data sharing	Training data specifics often kept secret
CODE	Publicly available, open source code	Closed source code, not publicly disclosed
DEVELOPMENT CYCLES	Slower due to scrutiny and collaboration	Faster development cycles, improved security
EASE OF USE	Has potentially less support services and infrastructure	Infrastructure and support services provided
CONTROL	Community collaboration, innovation	More internal control over systems
COMMERCIAL BENEFITS	Shared innovation	Maintains competitive edge, commercial benefits
SCRUTINY	Broader community identification of problems	Limited to internal resources for identification
RECRUITMENT	Attracts innovative developers	May attract developers seeking proprietary work
BIAS IDENTIFICATION	Transparency in training sources	Difficult to identify bias due to lack of transparency
SCALABILITY IMPROVEMENTS	Collective innovation accelerates scalability	Closed models may need to rely on internal efforts

© 2020 TECHTALKS. ALL RIGHTS RESERVED. TechTalks

Comparing Open AI and Closed AI (source)

Compute infrastructure: software and hardware

- **Software** — ML libraries/frameworks (TensorFlow, PyTorch, Scikit-learn), a programming language (Python), a distributed computing platform (Apache Spark/Hadoop), plus data preparation/cleaning and workload monitoring tools.
- **Hardware** — specialized hardware (GPUs/TPUs), increasingly cloud-based for scalable, cost-effective compute; accelerator chips optimized for training and inference workloads.

1.4 History of AI and the Evolution of Data Science

- **1956** — Dartmouth summer research project: the birth of AI as a field, built on the conjecture that every aspect of learning or intelligence can, in principle, be so precisely described that a machine can simulate it.
- **1956–1974** — **The Golden Years**: programs solving algebra word problems and learning English seem “astonishing.”
- **1974–1980** — **20th Century AI Winter**: capabilities remain limited, largely due to lack of computing power; only trivial problem versions handled.
- **1987–1993** — **A Renewed Interest**: business fascination with AI (especially expert systems) rises, then meets the reality of limitations.

AI summers see innovation and investment; AI winters see reduced interest and funding.

The current environment is fueled by exponential growth in computing infrastructure and tech megatrends: cloud, mobile, social, IoT, PETs, blockchain, computer vision, AR/VR, and the metaverse — driven by increasing computing/storage capacity, growth in available data, and development of neural-network-based learning machines.

Domain 1 Recap

- AI/ML definitions share four common elements: technology, automation, the role of humans, and output (content, predictions, recommendations, or decisions).
- AI systems are socio-technical — impacts flow from both technical design and social context — which is why cross-disciplinary teams and frameworks like the OECD Classification Framework matter.
- Generative AI creates new content; predictive AI forecasts from existing patterns — each has distinct training data needs, use cases, and risk profiles.
- ML training methods (supervised, unsupervised, semi-supervised, reinforcement) and the deep-learning/generative-AI/transformer landscape underpin most modern AI deployments.
- The AI technology stack spans data, models, APIs, and interfaces, running on a software/hardware compute layer — and choices between open- and closed-source foundation models carry real governance trade-offs.



Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: A mid-sized RBI-regulated Non-Banking Financial Company (“Free-AI NBFC”) wants to deploy a generative-AI chatbot for loan-collections follow-up and a predictive-AI model for credit scoring, but has no formal AI security or governance maturity yet.

- **Classify before you build:** Use the OECD Framework's five dimensions (People & Planet, Economic Context, Data & Input, AI Model, Task & Output) to classify each use case. The credit-scoring model is Predictive AI acting on sensitive financial data — a very different risk profile than the Generative AI chatbot drafting collection messages.
- **Match technology choice to maturity:** Given low security maturity, the NBFC should prefer a well-documented closed-source foundation model from an established vendor (faster to secure, vendor-supported) over a self-hosted open-source model it cannot yet harden — while noting the trade-off in transparency and bias auditability.
- **Build cross-disciplinary ownership early:** Because AI is socio-technical, the NBFC should pull in compliance, credit-risk, IT security, and customer-facing operations — not leave the model solely with the data science team — before it reaches customers.
- **Right-size the compute/security stack:** With limited in-house infrastructure, favor reputable cloud-hosted ML infrastructure with built-in access controls and logging rather than an ad-hoc on-premise stack the NBFC cannot yet secure or monitor.

Domain 2: Understanding AI Impacts and Responsible AI Principles

2.1 Core Risks and Harms Posed by AI Systems

Harms to an individual (civil rights, economic opportunity, safety)

- An inaccurate system can implicate people for crimes they did not commit, shifting the burden onto defendants to prove otherwise.
- Face recognition uniquely threatens free speech and freedom of association under the First Amendment, since identifiable photographs can be captured without knowledge.
- Collection/retention of face recognition data poses security risks — data can be breached or misused, and unlike an SSN or license number, faces cannot be changed.
- Because faces are exposed in public and often shared online, face recognition enables covert, remote, mass capture and identification — potentially including a person's dress and companions.
- Government surveillance can chill public debate and free association (the “spiral of silence” effect on those whose views differ from the majority).

Harms to a group (discrimination toward sub-groups)

- Face recognition disproportionately impacts people of color — misidentifying African Americans, ethnic minorities, young people, and women at higher rates.
- Because criminal databases already over-represent African Americans, Latinos, and immigrants (due to biased policing), people of color bear disproportionately more of the burden of face recognition inaccuracies.
- Mistaken matches to mugshot databases can wrongly deny employment; even correct matches disproportionately harm minority job seekers given unreliable FBI records.

Harms to society

- Democratic process, public trust in institutions, educational access, and job redistribution are all at stake.

Real risks and harms are more about “concentration of power in the hands of people, about reproducing systems of oppression, about damage to the information ecosystem, and about damage to the natural ecosystem (through profligate use of energy resources).” — Emily Bender

Harms to a company or institution (reputational, cultural, economic, acceleration risks)

- **Sensitive data exposure** — large datasets risk unintended exposure of confidential customer/business data (identity theft, fraud, loss of trust).
- **Cybersecurity vulnerabilities** — AI integration creates new entry points for hackers, risking data theft and operational/supply-chain disruption.
- **Data control concerns** — reliance on external AI vendors can create governance gaps, especially if vendors don't meet ESG/cybersecurity standards.
- **Opaque decision processes** — deep learning's “black box” nature hinders accountability and trust.

- **Accountability challenges** — hard to attribute responsibility when AI-driven decisions cause adverse outcomes.
- **Compliance complexity** — AI may not keep pace with the rapidly expanding body of ESG-related laws and standards.
- **Legal uncertainties** — rapidly evolving AI can outpace legal frameworks on liability, IP, and data use.

Harms to an ecosystem (natural resources, environment, supply chain)

- **High energy consumption** — training/running large models is computation-intensive with a significant carbon footprint.
- **Life-cycle impact of AI hardware** — production, operation, and disposal of servers/data centers contribute to e-waste and resource depletion.

2.2 Characteristics of Trustworthy AI Systems

- **Human-centric** — AI that amplifies and augments (not displaces) human abilities, preserving human control while operating transparently, delivering equitable outcomes, and respecting privacy.
- **Accountable** — the obligation of creators, operators, and regulators to ensure the system operates ethically, fairly, transparently, and compliantly; actions/decisions/outcomes must be traceable to a responsible entity.
- **Transparent** — the extent to which information about the system is available to stakeholders, including whether AI is used and how the model works.
- **Explainable (XAI)** — the ability to describe how an AI system generates a specific output or decision to a predetermined addressee; important for maintaining transparency and trust.
- **Privacy-enhanced** — Privacy-Enhancing Technologies (PETs) allow collection, processing, analysis, and sharing of information while safeguarding personal data, minimizing collection, maximizing security, and empowering individuals.
 - Federated learning — trains models across decentralized devices without transferring raw data to a central server; only aggregated updates are shared.
 - AI-generated synthetic data — generates data with the same statistical properties as real data, without PII.

2.3 Existing and Emerging Ethical Guidance on AI

Roots: FIPPs, European Court of Human Rights, and OECD principles

Fair Information Practice Principles (FIPPs) — widely accepted (though non-mandatory) principles agencies apply when evaluating systems affecting privacy:

- Access and Amendment
- Accountability
- Authority
- Minimization
- Quality and Integrity
- Individual Participation

- Purpose Specification and Use Limitation
- Security
- Transparency

European Court of Human Rights — rules on applications alleging violations of civil/political rights under the European Convention on Human Rights.

OECD Corporate Governance Principles — an effective governance framework, shareholder rights, the role of institutional investors, stakeholder roles, disclosure/transparency, and board responsibilities.

OECD AI Principles

- **Inclusive growth, sustainable development, and well-being** — augmenting human capability, advancing inclusion, reducing inequalities, protecting the environment.
- **Human-centred values and fairness** — respecting rule of law, human rights, and democratic values (freedom, dignity, privacy, non-discrimination, fairness, labor rights).
- **Transparency and explainability** — fostering understanding, awareness of interactions, enabling affected persons to understand and challenge outcomes.
- **Robustness, security and safety** — functioning appropriately under normal, foreseeable, or adverse conditions; traceability and systematic risk management.
- **Accountability** — AI actors accountable for proper functioning and respect of the above principles.

White House Blueprint for an AI Bill of Rights

- Safe and Effective Systems
- Algorithmic Discrimination Protections
- Data Privacy
- Notice and Explanation
- Human Alternatives, Considerations, and Fallback

Accompanied by “From Principles to Practice” — a handbook for incorporating these protections into policy and practice.

EU High-Level Expert Group on AI (HLEG)

- **Deliverable 1** — Ethics Guidelines for Trustworthy AI: a human-centric approach and 7 key requirements for trustworthiness.
- **Deliverable 2** — Policy and Investment Recommendations for Trustworthy AI: 33 recommendations for sustainability, growth, competitiveness, and inclusion.
- **Deliverable 3** — Assessment List for Trustworthy AI (ALTAI): a practical self-assessment checklist (web tool and PDF).
- **Deliverable 4** — Sectoral Considerations: implementation in Public Sector, Healthcare, and Manufacturing/IoT.

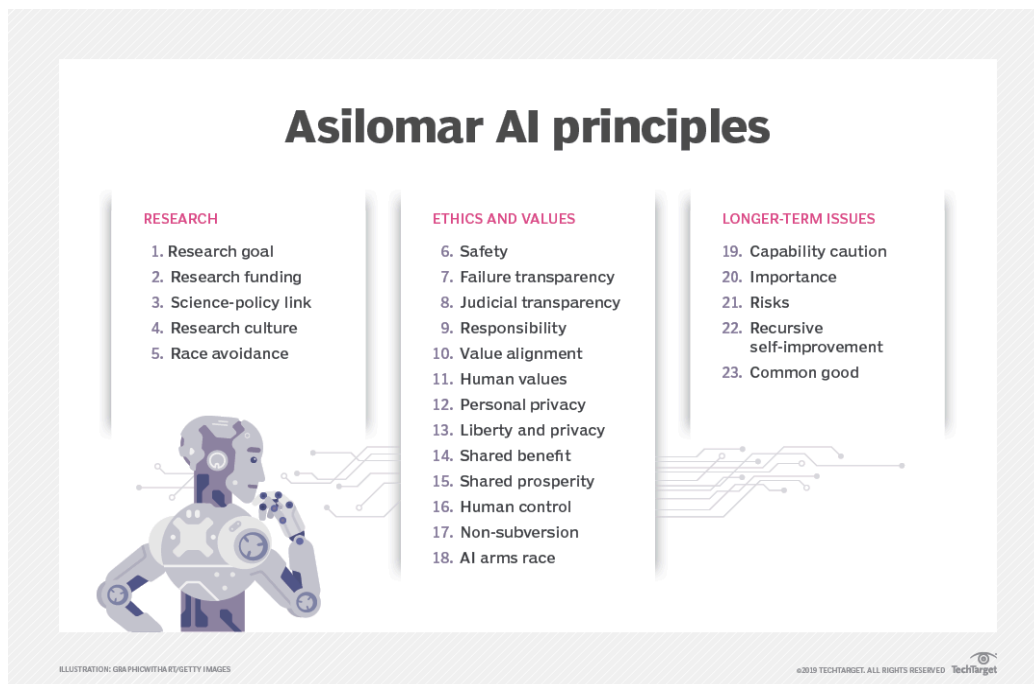
UNESCO Principles

Provide a basis to make AI systems work for the good of humanity, individuals, societies and the environment and ecosystems, and to prevent harm — while stimulating the peaceful use of AI systems.

Aims to bring a globally accepted normative instrument focused not only on values and principles but their practical realization via concrete policy recommendations, emphasizing gender equality and environmental/ecosystem protection.

Asilomar AI Principles

23 principles across 3 categories, developed at a conference sponsored by the Future of Life Institute.



Asilomar AI Principles — Research, Ethics & Values, Longer-term Issues

IEEE Initiative on Ethics of Autonomous and Intelligent Systems

To ensure every stakeholder involved in the design and development of autonomous and intelligent systems is educated, trained, and empowered to prioritize ethical considerations so that these technologies are advanced for the benefit of humanity.

- Eight general principles: human rights and well-being, transparency, accountability, effectiveness, competence, awareness of misuse, and data agency (giving individuals control over their data).
- Follows an ethics-by-design approach.

CNIL AI Action Plan (France)

- **Understanding AI systems and impacts** — protecting scraped web data, data transmitted by users, and rights over training/output data.
- **Guiding privacy-respecting AI development** — publishing guidance ahead of the EU AI Act, including data-sharing rules and generative-AI design recommendations.
- **Supporting innovation** — a regulatory sandbox and dialogue with research teams and R&D centers.
- **Auditing and controlling AI systems** — developing audit tools and investigating AI-related complaints.

Domain 2 Recap

- AI harms occur at multiple levels — individual (civil rights, safety), group (discrimination), society (trust, democracy), company (reputational, legal), and ecosystem (energy, e-waste).
- Trustworthy AI rests on being human-centric, accountable, transparent, explainable, privacy-enhanced, and fair.
- Modern ethical guidance (OECD AI Principles, EU HLEG, UNESCO, Asilomar, IEEE) traces back to foundational privacy principles (FIPPs) and human-rights law.

Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: The NBFC's credit-scoring model risks disproportionately rejecting applicants from certain pin-codes or demographic segments, and the collections chatbot logs customer financial conversations with minimal access controls.

- **Run a harms inventory before go-live:** Map potential individual harm (wrongful loan denial), group harm (disparate impact on a community segment), and institutional harm (RBI regulatory action, reputational damage) — using the individual / group / society / company / ecosystem lens from this domain.
- **Adopt trustworthy-AI characteristics as minimum bar:** Even with low maturity, the NBFC should document explainability for every credit decision (why an applicant was scored as they were) — this is both an OECD/EU-HLEG expectation and increasingly an RBI fair-lending expectation.
- **Borrow a ready-made ethics scaffold:** Rather than building principles from scratch, adopt the EU HLEG's ALTAI self-assessment checklist or the OECD AI Principles as an interim governance baseline while formal NBFC policy is developed.
- **Apply PETs pragmatically:** Even without full security maturity, simple measures — minimizing customer data sent to the chatbot's LLM provider, masking account numbers, and setting data-retention limits — meaningfully reduce privacy risk at low cost.

Domain 3: Understanding How Current Laws Apply to AI Systems

3.1 Existing Laws That Interact With AI Use

Unfair and deceptive practices

- Federal Trade Commission (FTC) Act (US) — Wheeler-Lea Act of 1938
- EU Directive on unfair commercial practices (2005)
- Children's Online Privacy Protection Act (COPPA) — governs collection of minors' information
- Gramm-Leach-Bliley Act (GLBA) — personal information collected by banks/financial institutions
- Telemarketing Sales Rule, Telephone Consumer Protection Act (1991), Do-Not-Call Registry
- Junk Fax Protection Act of 2005 (JFPA)
- CAN-SPAM Act (2003) and the Wireless Domain Registry
- Telecommunications Act of 1996 and Customer Proprietary Network Information (CPNI)
- Cable Communications Policy Act of 1984
- Video Privacy Protection Act (1998) and its 2012 Amendments
- Driver's Privacy Protection Act (DPPA)

Non-discrimination laws (credit, employment, insurance, housing)

The FCRA regulates “consumer reporting agencies” and could apply to a generative AI service that regularly produces reports about individuals' character, reputation, or mode of living used for employment purposes.

- Confidentiality of Substance Use Disorder Patient Records Rule — bars use of patient info to initiate criminal charges/investigations
- Fair Credit Reporting Act (FCRA) — regulates collection/use of credit information
- Fair and Accurate Credit Transactions Act (2009, FACTA) — identity-theft protections, “red flags” rules
- Privacy Protection Act of 1980 (PPA) — requires a subpoena for First-Amendment-protected materials
- Title VII of the Civil Rights Act of 1964 — prohibits employment discrimination (race, color, religion, sex, national origin)
- Title I of the ADA — prohibits employment discrimination against qualified individuals with disabilities
- Genetic Information Nondiscrimination Act of 2008 (GINA)
- Illinois AI Video Interview Act — requires disclosure/consent for AI-analyzed interviews and demographic bias reporting
- Maryland HB 1202 — bars facial recognition in hiring without applicant consent
- NYC regulation — requires a bias audit and applicant notice for automated employment decision tools
- The Wiretap Act

Product safety and IP law

- Consumer Product Safety Act (CPSA, 1972) — protects against injury risk, enables safety evaluation, sets consistent standards
- EU General Product Safety Regulation (GPSR) — requires all consumer products on EU markets to be safe

USPTO, US Copyright Office, and courts have yet to fully establish clear guidelines on AI-created content or inventions, but generally recognize rights only for human authors and inventors — similarly at the EPO and EUIPO in Europe.

EU Digital Services Act (DSA) — transparency of recommender systems

- Applies to all intermediary services offered to recipients located in the EU, regardless of provider location.
- **Article 26** — online platforms must clearly identify advertisements; targeted ads based on minors' data or special-category data are prohibited.
- **Article 27** — platforms using recommender systems must disclose main parameters and options to modify them in their T&Cs.
- **Article 38** — Very Large Online Platforms/Search Engines (VLOPs/VLOSEs) must offer at least one non-profiling-based recommender option.

Privacy laws concerning the use of data

- Federal Privacy Act of 1974 and E-Government Act of 2002 — require agencies to address privacy implications of systems collecting identifiable public information
- HIPAA — governs collection of health information
- HITECH Act (2009) — increased HIPAA penalties, greater individual access rights
- FERPA — protects privacy of student education records
- PPRA (1978) — prevents sale of student information for commercial purposes
- US state privacy laws — CCPA/CPRA, VCDPA, CPA, CTDPA, and similar laws in Montana, Delaware, Utah, Oregon, Iowa, New Jersey, Indiana, Tennessee, and Texas (TDPSA)

3.2 Key GDPR Intersections

Automated decision-making, DPIAs, and anonymization

The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

The data controller shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention, to express his or her point of view, and to contest the decision.

- Creating a training dataset that involves PII can create “high risks” to rights/freedoms, making a Data Protection Impact Assessment (DPIA) mandatory — distinct from an AI Conformity Assessment.
- Anonymizing training data can mitigate concerns by separating information from the individual.

AI Conformity Assessments (CA) vs. DPIAs

- A high-risk AI system requires a Conformity Assessment before entering the EU market to confirm compliance with the AI Act.
- A CA focuses on compliance with specific legal mitigation requirements; a DPIA is an accountability tool requiring controllers to assess risk-based decisions and report on their decision-making process.
- Because high-risk AI systems that process personal data will almost always trigger a DPIA, the CA can form the foundation of the DPIA — and, where the provider is also the controller, both may be performed by the same entity.

Human supervision of algorithmic systems

Users have the right to:

- Know about the automated decision;
- Understand the decision-making logic;
- Challenge the decision and share their perspective; and
- Request human intervention for decision review.

Data controllers must therefore plan for human intervention so individuals can review, understand, and contest decisions.

Right to meaningful information about the logic of AI systems

- The existence of automated decision-making, including profiling.

“Meaningful information about the logic involved” should be understood as information about the algorithmic method used, not an explanation of a specific decision's full rationale — e.g., input data and general parameters, not source code.

- The significance and envisaged consequences of the processing for the individual.

3.3 Liability Reform

EU Product Liability Law Reform

- **Article 4** — brings software (operating systems, firmware, applications, AI systems) within scope of EU product liability law.
- **Article 7** — extends liability to manufacturers of defective components, distributors, fulfilment providers, and online platforms.
- **Articles 8 & 9** — provide a disclosure regime and rebuttable presumptions to assist claimants.

AI Product Liability Directive

Complements the AI Act by introducing a new liability regime that ensures legal certainty, enhances consumer trust in AI, and assists consumers' liability claims for damage caused by AI-enabled products and services available in, or operating within, the EU market.

U.S. federal agency involvement — Executive Order 14091

- “Further Advancing Racial Equity and Support for Underserved Communities Through the Federal Government” — requires agencies to integrate equity into AI planning/decision-making.

When designing, developing, acquiring, and using artificial intelligence and automated systems, agencies shall do so, consistent with applicable law, in a manner that advances equity.

- “Algorithmic discrimination” refers to automated systems contributing to unjustified different treatment or impacts disfavoring people based on protected characteristics (race, sex, religion, age, disability, national origin, and more).

Domain 3 Recap

- AI does not operate in a legal vacuum — existing unfair/deceptive-practice, anti-discrimination, product-safety, IP, privacy, and DSA transparency laws already apply.
- Under GDPR, automated decisions with legal or similarly significant effects trigger rights to human intervention, explanation, and challenge — and DPIAs and Conformity Assessments will often overlap for high-risk systems.
- Liability frameworks are evolving fast (EU Product Liability reform, AI Product Liability Directive, US Executive Order 14091) to fill gaps traditional software liability doesn't cover.

Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: The NBFC's credit-scoring model produces automated approve/reject decisions with no human review step, and the underlying training data includes past loan-officer decisions that may already carry bias.

- **Map applicable law like a checklist:** Even though GDPR itself may not directly apply, India's existing consumer-protection, fair-lending, and (upcoming) DPDP Act obligations mirror the GDPR concepts above — the NBFC should still build a human-intervention path for adverse credit decisions.
- **Treat 'automated decision + legal effect' as a trigger:** Because a loan rejection has a real financial/legal effect on the applicant, the NBFC should give applicants a right to know an algorithm was involved, a plain-language reason, and a path to request human review — well before any formal India-specific AI law mandates it.
- **Run a DPIA-equivalent for the credit model before scale-up:** Given low maturity, a lightweight internal impact assessment (data sources, PII used, bias testing, retention) can substitute for a formal DPIA/CA until the NBFC builds full governance capacity.
- **Assign liability ownership internally now:** Decide today — before an incident occurs — whether the vendor supplying the credit model, the NBFC as deployer, or both are accountable for a wrong decision, mirroring how the EU AI Product Liability Directive allocates responsibility across providers and deployers.

Domain 4: Understanding the Existing and Emerging AI Laws and Standards

4.1 Requirements of the EU AI Act

Risk classification framework

Tier	Description
Prohibited	A significant threat to fundamental rights, democratic processes, and societal values; likely to compromise critical infrastructure integrity and lead to serious incidents.
High Risk	Primarily used in critical sectors (healthcare, transportation, law enforcement); subject to strict conformity assessments for accuracy, robustness, and cybersecurity, plus mandatory human oversight.
Limited Risk	Less risky, fewer regulatory constraints, but still subject to specific transparency obligations (clear explanations of how the system works, what data it uses, and how decisions are made).
Low Risk	E.g., AI-powered video games, spam filters; regulatory burden is minimized to promote innovation where risk is negligible.

Requirements for high-risk systems and foundation models

Providers must demonstrate the technology and its use do not pose a significant threat to health, safety, and fundamental rights, through:

- Risk management, data governance, monitoring, and record-keeping practices
- Detailed documentation, transparency, and human-oversight obligations
- Standards for accuracy, robustness, and cybersecurity

Notification requirements

The AI Act requires developers of high-risk AI to set up a reporting system for serious incidents as part of wider post-market monitoring. A serious incident is a malfunction that led to, might have led to, or might lead to serious damage to a person's health or death, serious damage to property or the environment, disruption of critical infrastructure, or violation of fundamental rights under EU law.

Developers — and in some cases deployers — must notify the relevant authorities and maintain records/logs to demonstrate compliance in case of ex-post audits.

Enforcement framework and penalties

- Penalties follow a three-tiered system — more severe violations carry heftier fines.
- Prohibited-system violations: up to €35,000,000 or 7% of worldwide annual turnover (whichever is higher).

- Incorrect/incomplete/misleading information to authorities: up to €7,500,000 or 1% of worldwide annual turnover (whichever is higher).
- Penalties can be issued to providers, deployers, importers, distributors, and notified bodies.

```
graph LR; Penalties --> Providers[General fines for providers of AI systems]; Penalties --> Operators[General fines for operators of AI systems]; Penalties --> Institutions[For Union institutions, agencies and bodies];
```

General fines for providers of AI systems	Up to 35 000 000 EUR or, if the offender is a company, up to 7 % of its total worldwide annual turnover for the preceding financial year, whichever is higher	Non-compliance with the prohibition of the artificial intelligence practices under Article 5
	Up to 15 000 000 EUR or, if the offender is a company, up to 3% of its total worldwide annual turnover for the preceding financial year, whichever is higher	Non-compliance with the following: • obligations of providers pursuant to Article 16 • obligations of authorised representatives pursuant to Article 25 • obligations of importers pursuant to Article 26 • obligations of distributors pursuant to Article 27 • obligations of deployers pursuant to Article 29, paragraphs 1 to 6a • requirements and obligations of notified bodies pursuant to Article 33, 34(1), 34(3), 34(4), 34a • transparency obligations for providers and users pursuant to Article 52
	Up to 7 500 000 EUR or, if the offender is a company, up to 1 % of its total worldwide annual turnover for the preceding financial year, whichever is higher	The supply of incorrect, incomplete or misleading information to notified bodies and national competent authorities in reply to a request
General fines for operators of AI systems	Up to 15 000 000 EUR or, if the offender is a company, up to 3% of its total worldwide annual turnover for the preceding financial year, whichever is higher	In one of the following: • Infringement of the GPAI-relevant provisions • Failure to comply with a request for document or information pursuant to Article 68i or supply of incorrect, incomplete or misleading information • Failure to comply with a measure requested under Article 68k • Failure to make available to the Commission access to the general purpose AI model or general purpose AI model with systemic risk with a view to conduct an evaluation pursuant to Article 68j
For Union institutions, agencies and bodies	Up to EUR 1 500 000	Non-compliance with the prohibition of the artificial intelligence practices under Article 5
	Up to EUR 750 000	Non-compliance of the AI system with any requirements or obligations

www.holisticai.com

 Holistic AI

EU AI Act — Penalties framework (Holistic AI)

Testing innovative AI and research exemptions

The AI Act's exception [to process special categories of personal data to detect and correct bias] applies to developers and entities outsourcing the development of AI systems, for non-private use. It does not seem to apply to organizations renting a fully developed AI system as a service.

Transparency requirements

- High-risk AI systems must be registered in an EU-wide public database.
- There is an obligation to warn people that they are interacting with an AI system.

4.2 Other Emerging Global Laws

Canada — Artificial Intelligence and Data Act (AIDA / Bill C-27)

AIDA provides a definition of “person” that includes trusts, partnerships, unincorporated associations, and any other legal entity, and clarifies when such a person is a “person responsible” for an AI system: designing, developing, making available for use, or managing its operation in interprovincial/international trade.

Responsibilities include:

- Ensuring anonymization of data
- Assessing whether a system is “high-impact”
- Establishing risk-related measures
- Monitoring and record-keeping on risk mitigation
- Publishing a plain-language description of high-impact systems

If adopted, AIDA will replace PIPEDA.

U.S. state laws governing AI use

- **Algorithmic discrimination bills** — place the burden on developers/deployers to prevent discriminatory outcomes via impact assessments, disclosure, opt-outs, and explanations of AI use (California, Connecticut, Vermont, Hawaii, Illinois, New York, Oklahoma, Rhode Island, Washington).
- **Automated employment decision tools (AEDTs)** — require advance notice/consent, explanation of assessed qualifications, and regular bias audits (Illinois, Massachusetts, New Jersey, New York, Vermont).
- **AI Bill of Rights state laws** — rights to know about AI interaction/data use, non-discrimination, data agency, understanding outcomes, and opt-out (Oklahoma, New York).
- **Working group bills** — commissions/agencies to study AI and recommend future regulation (Utah, Florida, Hawaii, Massachusetts).

China — Cyberspace Administration draft regulations on generative AI

Applies to domestic companies and overseas providers offering generative AI services to the Chinese public (not enterprise use).

In development and use, providers must:

- Not generate illegal content (false or harmful information)
- Prevent discriminatory content
- Avoid monopolistic or unfair-competition uses of algorithm/data/platform advantages
- Not infringe portrait, reputation, honor, privacy, or personal-information rights
- Increase transparency and content accuracy/reliability

For training data, providers must:

- Use legitimately sourced data and foundation models
- Not infringe others' IP rights
- Obtain personal data with consent or other lawful basis
- Improve data quality, truthfulness, accuracy, objectivity, and diversity

When providing services, providers must:

- Sign service agreements specifying user/provider rights and obligations
- Guide legal use and prevent user over-reliance/addiction
- Limit collection/retention of identifying input data and usage records
- Handle data-subject requests and tag AI-generated media
- Stop/delete illegal content and report to authorities; warn or restrict users engaged in illegal use
- Establish a complaints-handling mechanism

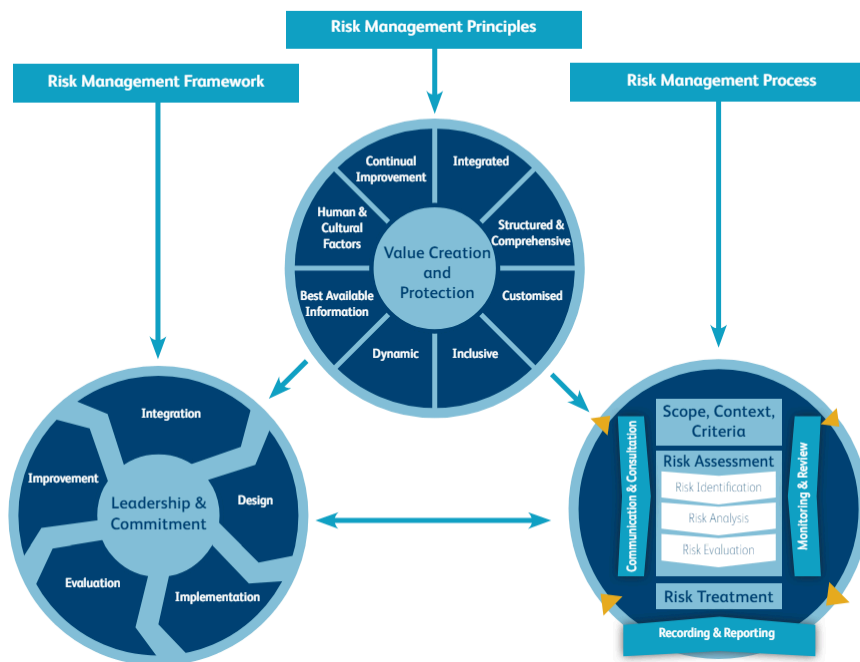
Providers must also conduct safety assessments/record-filing for services with public-opinion or social-mobilization capability, and cooperate with regulator (CAC) supervisory checks.

4.3 Major Risk Management Frameworks and Standards

ISO 31000:2018 Risk Management — Guidelines

A management system is the framework of policies, processes and procedures employed by an organization to ensure that it can fulfill the tasks required to achieve its purpose and objectives.

- Covers governance and culture; strategy and objective-setting; performance; information, communication, and reporting; and review/revision of practices.
- Emphasizes leadership endorsement, organizational governance, and the iterative nature of risk management.



ISO 31000:2018 Risk Management Framework and Process

NIST AI Risk Management Framework (AI RMF)

- Voluntary framework to incorporate trustworthiness into the design, development, use, and evaluation of AI products, services, and systems.
- Organized into four core functions: Govern, Map, Measure, and Manage.
- Defines seven characteristics of trustworthy AI: valid and reliable, safe, secure and resilient, accountable and transparent, explainable and interpretable, privacy-enhanced, and fair with harmful bias managed.

(A full summary and control table for the NIST AI RMF appears at the end of this study guide.)

EU AI Act (proposed regulation)

- The first comprehensive AI law by a major regulator; most obligations fall on providers (developers) of high-risk systems.
- “Users” are natural/legal persons deploying an AI system professionally, not affected end-users.
- All GPAI model providers must give technical documentation, instructions for use, comply with the Copyright Directive, and publish a training-content summary.

- Free/open-licence GPAI providers only need copyright compliance and a training-data summary, unless they present systemic risk.
- All systemic-risk GPAI providers (open or closed) must conduct model evaluations, adversarial testing, track/report serious incidents, and ensure cybersecurity.

Council of Europe HUDERIA Framework

The Human Rights, Democracy, and the Rule of Law Assurance Framework for AI Systems defines a methodology for AI impact assessments from a human-rights, democracy, and rule-of-law perspective, based on Council of Europe standards.

IEEE 7000-21 — Model Process for Addressing Ethical Concerns in System Design

Integrates ethical and functional requirements in systems engineering design and development in order to mitigate risk and increase innovation.

Establishes traceability of ethical values through concept of operations, ethical requirements, and ethical risk-based design; applicable to organizations of any size or life-cycle model.

ISO/IEC Guide 51 — Safety Aspects

Aims to reduce risk arising from the design, production, distribution, use (including maintenance), and destruction or disposal of products or systems — including use by vulnerable consumers.

Singapore Model AI Governance Framework

- Provides detailed, implementable guidance to private-sector organizations on ethical/governance issues in deploying AI.
- Decisions made by AI should be explainable, transparent, and fair.
- AI systems should be human-centric.

Domain 4 Recap

- The EU AI Act uses a four-tier risk pyramid (prohibited / high / limited / low) with escalating obligations, mandatory registration for high-risk systems, and a tiered penalty regime up to €35m or 7% of global turnover.
- Emerging global regimes — Canada's AIDA, US state laws, and China's generative-AI regulations — converge on similar themes: impact assessments, transparency, bias mitigation, and accountability for developers and deployers alike.
- Multiple international risk-management standards (ISO 31000, NIST AI RMF, HUDERIA, IEEE 7000-21, Singapore's Model Framework) offer complementary — not competing — structures an organization can blend together.



Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: The NBFC operates only in India today but is evaluating a foundation-model vendor based in the EU, and RBI has signaled it expects NBFCs to demonstrate 'responsible AI' practices even absent an India-specific AI law.

- **Use the EU AI Act as a de-facto benchmark:** Even without direct extraterritorial exposure, classify the credit-scoring model against the EU AI Act's four tiers (it would likely be treated as high-risk, given credit-worthiness assessment is an explicit high-risk use case) — and build documentation, human oversight, and testing to that bar.
- **Borrow, don't reinvent, a risk framework:** Given low maturity, adopt NIST AI RMF's Govern-Map-Measure-Manage structure (detailed at the end of this guide) as the NBFC's internal AI risk-management skeleton rather than designing one from scratch.
- **Vendor due diligence checklist:** Before signing with the EU-based foundation-model vendor, request its GPAI technical documentation, training-data summary, and evidence of systemic-risk testing — mirroring EU AI Act GPAI obligations — to avoid inheriting undocumented risk.
- **Plan for mandatory disclosure now:** Build a 'serious incident' log and customer-facing AI disclosure ('You are interacting with an AI-assisted collections agent') today, since these transparency obligations are converging globally and will very likely apply to Indian NBFCs soon.

Domain 5: Understanding the AI Development Life Cycle

5.1 Planning Phase

- Determine the business objectives and requirements.
- Determine the scope of the project.
- Determine the governance structure and responsibilities.

5.2 Design Phase

- Implement a data strategy that includes:
 - Data gathering, wrangling, cleansing, and labeling.
 - Applying Privacy-Enhancing Technologies (PETs) — anonymization, minimization, differential privacy, federated learning.
- Determine AI system architecture and model selection — choosing the algorithm according to the desired level of accuracy and interpretability.

5.3 Development Phase

- Build the model.
- Perform feature engineering.
- Perform model training.
- Perform model testing and validation.

5.4 Implementation Phase

- Perform readiness assessments.
- Deploy the model into production.
- Monitor and validate the model.
- Maintain the model.

Domain 5 Recap

- The AI development lifecycle runs Plan → Design → Development → Implementation, with governance, data strategy (including PETs), and human-oversight decisions embedded at each stage — not bolted on at the end.
- Model selection should balance accuracy against interpretability, and readiness assessments should precede every production deployment.



Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: The NBFC's data-science team has already started building the credit-scoring model without a documented lifecycle process, using loan officers' historical decisions as training data.

- **Retrofit a lightweight lifecycle gate now:** Insert a simple go/no-go checkpoint at each phase — Plan (objectives + governance sign-off), Design (data strategy + PETs review), Development (bias/testing sign-off), Implementation (readiness assessment) — even if each gate is just a one-page checklist initially.
- **Prioritize interpretability over marginal accuracy for credit scoring:** Given RBI's fair-lending expectations and the NBFC's low AI maturity, choose a more interpretable model (e.g., logistic regression or decision trees) over a less-explainable deep model, even if it sacrifices a few points of predictive accuracy.
- **Apply data minimization at the Design phase:** Strip or mask fields (like religion-correlated surnames or exact addresses) from training data before model-building, rather than trying to de-bias after the fact.
- **Don't skip 'maintain':** Set a fixed cadence (e.g., quarterly) to re-validate the model against new loan performance data — since a model that was fair at launch can drift as India's credit landscape and applicant pool change.

Domain 6: Implementing Responsible AI Governance and Risk Management

6.1 Interoperability of AI Risk Management With Other Operational Risk Strategies

AI risk management should interoperate with security risk, privacy risk, and business risk.

The AI models constitute valuable intellectual assets, demanding features that prevent unauthorized access or tampering.

Depending on the sector — such as healthcare or finance — the stack must be compliant with industry-specific regulations like HIPAA or PCI-DSS.

6.2 Integrating AI Governance Principles Into the Company

- Adopt a pro-innovation mindset.
- Ensure governance is risk-centric.
- Ensure planning and design is consensus-driven.
- Ensure the team is outcome-focused.
- Adopt a non-prescriptive approach to allow for intelligent self-management.
- Ensure the framework is law-, industry-, and technology-agnostic.

6.3 Establishing an AI Governance Infrastructure

- Determine if you are a developer, deployer (making an AI system available to third parties), or user; understand how responsibilities differ; establish governance processes for all parties and a framework for procuring/assessing AI solutions.
- Establish roles and responsibilities for AI governance people/groups: the chief privacy officer, chief ethics officer, office for responsible AI, AI governance committee, ethics board, architecture steering groups, AI project managers, etc.
- Advocate for AI governance support from senior leadership and tech teams by understanding pressures on tech teams, how data-science/model-ops teams work, and by influencing behavioral/cultural change.
- Establish organizational risk strategy and tolerance.
- Develop a central inventory of AI/ML applications and a repository of algorithms.
- Develop responsible AI accountability policies and incentive structures.
- Understand AI regulatory requirements.
- Set common AI terms and taxonomy for the organization.
- Provide knowledge resources and training to foster a culture of continuous ethical behavior.
- Determine AI maturity levels of business functions and address insufficiencies.
- Use and adapt existing privacy and data governance practices for AI management.

- Create policies to manage third-party risk, ensuring end-to-end accountability.
- Understand differences in norms/expectations across countries.

6.4 Map, Plan, and Scope the AI Project

- Define the business case and perform cost/benefit analysis, weighing trade-offs in system design (“Why AI/ML?”).
- Identify and classify internal/external risks and contributing factors (prohibitive, major, moderate).
- Construct a probability/severity harms matrix and a risk mitigation hierarchy.
- Perform an algorithmic impact assessment, leveraging PIAs as a starting point and tailoring to the AI process — know when to perform one and who to involve.
- Establish the level of human involvement/oversight in AI decision-making.
- Conduct a stakeholder engagement process:
 - Evaluate stakeholder salience.
 - Include diversity of demographics, disciplines, experience, expertise, and backgrounds.
 - Perform a positionality exercise.
 - Determine level of engagement and establish engagement methods.
 - Identify AI actors during design, development, and deployment phases.
 - Create communication plans for regulators and consumers reflecting compliance/disclosure obligations (UI copy, FAQs, documentation, model/system cards).
- Determine feasibility of optionality and redress.
- Chart data lineage and provenance, ensuring data is representative, accurate, and unbiased.
- Use statistical sampling to identify data gaps.
- Solicit early and continuous feedback from those most impacted by AI systems.
- Use the Test, Evaluation, Verification, Validation (TEVV) process.
- Create a preliminary analysis report on risk factors and proportionate management.

6.5 Test and Validate the AI System During Development

Evaluate trustworthiness, validity, safety, security, privacy, and fairness using:

- Edge cases, unseen data, or potential malicious input to test AI models; conduct repeatability assessments.
- Completed model cards / fact sheets.
- Counterfactual explanations (CFEs).
- Adversarial testing and threat modeling to identify security threats.
- The OECD catalog of tools and metrics for trustworthy AI.
- Multiple layers of mitigation to stop errors/failures at different levels or modules.
- Understanding trade-offs among mitigation strategies.
- Applying key concepts of privacy-preserving machine learning and PETs.

Understand why AI systems fail — examples include brittleness, hallucinations, embedded bias, catastrophic forgetting, uncertainty, and false positives.

- Determine the degree of remediability of adverse impacts.
- Conduct risk tracking to document how risks change over time.
- Consider and select among different deployment strategies.

6.6 Manage and Monitor AI Systems After Deployment

- Perform post-hoc testing to determine if AI system goals were achieved, remaining aware of “automation bias.”
- Prioritize, triage, and respond to internal and external risks.
- Ensure processes exist to deactivate or localize AI systems as necessary (e.g., regulatory requirements or performance issues).
- Continuously improve/maintain systems by tuning and retraining with new data and human feedback.
- Determine the need for challenger models to supplant the champion model.
- Version each model and connect it to its training datasets.
- Continuously monitor risks from third parties, including bad actors.
- Maintain and monitor communication plans; inform users when the AI system's capabilities are updated.
- Assess potential harms of publishing research derived from AI models.
- Conduct bug bashing and red teaming exercises.
- Forecast and reduce risks of secondary/unintended uses and downstream harm.

Domain 6 Recap

- AI governance must interoperate with (not duplicate) existing security, privacy, and business risk management, and be built on clear roles: developer, deployer, or user.
- Project scoping runs through impact assessments, stakeholder engagement, and data lineage checks before a line of model code is even written.
- Testing spans edge cases, adversarial/red-team testing, model cards, and CFEs — and post-deployment management requires ongoing monitoring, versioning, and incident communication.

Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: The NBFC has no AI governance committee, no model inventory, and no red-teaming capability — the credit-scoring and collections-chatbot projects were greenlit directly by business teams.

- **Stand up a minimal governance structure first:** Before scaling either use case, appoint a small cross-functional AI governance committee (compliance, IT security, credit risk, one business sponsor) with authority to pause deployments — even a 3-person committee beats none.

- **Start a model inventory today:** A simple spreadsheet listing every AI/ML use case, its owner, risk tier, and last review date is a low-cost first step toward the 'central inventory of AI/ML applications' this domain calls for.
- **Right-size testing to maturity:** Full adversarial red-teaming may be out of reach initially — but the NBFC can still run basic edge-case testing (e.g., feeding the credit model unusual but plausible applicant profiles) and document a simple model card before go-live.
- **Build the monitoring habit, not just the launch habit:** Commit to monthly post-deployment checks — approval-rate drift by segment for the credit model, and escalation/complaint rates for the chatbot — so problems surface before they become RBI findings or press stories.

Domain 7: Contemplating Ongoing Issues and Concerns

7.1 Legal Issues

Tort liability and web-scraping for AI training

A central open question: how will a coherent tort liability framework adapt to AI's unique circumstances and allocate responsibility among developers, deployers, and users?

In the US:

- Computer Fraud and Abuse Act (1986) — expanded by the USA PATRIOT Act (2001) and the Identity Theft Enforcement and Restitution Act (2008).
- Under the CCPA Final Regulations (§ 7012(h)), a business that neither collects nor controls collection of personal information directly from a consumer need not provide Notice at Collection if it neither sells nor shares that information.
- No notice is required for: a scraper that doesn't sell scraped PII; a scraper using scraped data for its own purposes (even marketing); or a scraper that de-identifies data before selling it.
- A scraper that sells collections of data including PII would need to provide notice at collection — potentially applicable to AI products trained on scraped web data.

In the EU:

- GDPR outlines six lawful bases for data collection/processing: consent, contract, legal obligation, vital interest, public task, and legitimate interest — these Article 6 requirements generally apply whether data comes from a public source or the data subject directly.

Challenges surrounding AI model and data licensing

- **Intellectual Property** — What IP rights exist in AI-generated output? Can AI models create trade secrets, copyrights, or inventive subject matter, and who owns the resulting rights (licensor, licensee, or the model itself)?
- **Performance and Reliability** — Licensees should insist on minimum performance metrics (accuracy, reliability, robustness) and craft warranties/indemnities so they don't unreasonably bear underperformance risk.
- **Data Protection and Confidentiality** — Using licensee data to improve AI products raises privacy/cybersecurity concerns beyond typical software licenses; licensees must ensure data use aligns with privacy laws and their own privacy notices, and track evolving state AI/automated-decision laws.

Respecting IP rights in generative systems

Resulting generative AI models need not be trained from scratch but can build upon open-source generative AI that used lawfully sourced content — enabling creators to produce content in their own style with an audit trail to their own data, or to license such tools with cleared title in both training data and outputs.

AI systems can generate new copyright-protectable works, such as artwork or music, but most copyright statutes do not yet clearly define who owns machine-generated works.

7.2 User Concerns

Educating users on AI functions and limitations

AI Literacy is about equipping individuals with the knowledge and skills to understand, use, and interact with AI responsibly and effectively — enabling informed decisions and navigating the ethical considerations AI presents.

Upskilling and reskilling the workforce

Nurturing complementary human skills lets the workforce integrate seamlessly with AI:

- Creativity and innovation through critical thinking and problem-solving, leveraging AI's insights for groundbreaking solutions.
- Communication and collaboration — translating AI's findings into actionable strategies.
- Emotional intelligence and social skills to foster trust in AI-driven environments.
- Ethical decision-making and bias awareness to ensure AI is used responsibly.

Reskilling (learning new skills for new roles) and upskilling (enhancing existing skills) matter because they:

- Keep workers competitive for hiring and promotion.
- Increase job satisfaction through engagement.
- Improve productivity and efficiency.
- Reduce the risk of job displacement from automation.

People leaders can leverage AI/ML for skilling by:

- Assessing skill gaps needed for future roles.
- Developing or partnering on training programs.
- Providing financial assistance for training.
- Promoting a culture of lifelong learning.

Opt-out for a non-AI alternative

You should be able to opt out, where appropriate, and have access to a person who can quickly consider and remedy problems you encounter. You should be able to opt out from automated systems in favor of a human alternative, where appropriate.

7.3 AI Auditing and Accountability Issues

- How can we build a global profession of certified third-party auditors, with consistent frameworks and standards?
- What markers or indicators determine when an AI system should be subject to enhanced accountability, such as third-party audits (e.g., automated decision-making, sensitive data)?
- How do we enable companies to remain productive using automated governance checks while adapting quickly to evolving standards and technology?

7.4 Other Notes

- **Privacy self-defense** — behaviors such as abandoning an online purchase, deleting an app, or avoiding a website due to privacy concerns; consumers who lose trust in data practices are more likely to engage in these self-protective behaviors.

The European Commission's Ethical Guidelines for Trustworthy AI outline four “ethical imperatives”: respect human autonomy, prevent harm, incorporate fairness, and enable explicability — with a further layer advising AI respect human dignity, individual freedom, democracy, justice, the rule of law, equality, non-discrimination, solidarity, and citizens' rights.

Domain 7 Recap

- Tort liability, web-scraping legality, and AI model/data licensing remain unsettled legal terrain — organizations should build contracts and controls assuming ambiguity, not certainty.
- User trust depends on AI literacy, workforce upskilling, and a genuine opt-out to a human alternative — not just technical compliance.
- Third-party AI auditing is an emerging discipline without a single global standard yet — organizations should get ahead of it rather than wait for mandates.

Applying This in Practice — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: Customers have started complaining they can't reach a human agent when the collections chatbot gives confusing repayment guidance, and the NBFC has no plan for what happens if the foundation-model vendor's licensing terms change.

- **Guarantee a human opt-out today:** Add a clear, one-tap 'talk to a human agent' escape hatch in the chatbot flow — this is both good customer experience and aligned with the AI Bill of Rights principle of human alternatives, and is low-cost to implement even at low AI maturity.
- **Negotiate licensing terms defensively:** Before renewing the foundation-model vendor contract, clarify in writing who owns outputs generated for customers, what performance/uptime guarantees exist, and how customer data shared with the vendor is protected and not reused to train the vendor's other customers' models.
- **Invest in frontline AI literacy first:** Since full technical governance will take time, start with a half-day training for collections and credit staff on what the AI models can and cannot reliably do — cheap, fast, and reduces the risk of staff blindly trusting flawed AI output.
- **Get audit-ready early:** Even without a certified third-party AI auditor engaged yet, keep model documentation, testing records, and incident logs audit-ready — so that when RBI or a customer ombudsman asks, the NBFC isn't starting from zero.

NIST AI Risk Management Framework (AI RMF 1.0) — Summary

Overview

The NIST Artificial Intelligence Risk Management Framework (AI RMF 1.0), published by the U.S. National Institute of Standards and Technology in January 2023, is a voluntary, non-sector-specific, use-case-agnostic framework that helps organizations manage risks in the design, development, deployment, and use of AI systems. It is directed by the National Artificial Intelligence Initiative Act of 2020.

Seven Characteristics of Trustworthy AI

NIST defines trustworthy AI systems as those that are:

- **Valid and reliable** — accurate and robust, performing as required under expected conditions over time.
- **Safe** — do not, under defined conditions, endanger human life, health, property, or the environment.
- **Secure and resilient** — can withstand adversarial events or unexpected changes and maintain confidentiality, integrity, and availability.
- **Accountable and transparent** — outputs and decisions can be traced to a responsible entity, with meaningful information available to stakeholders.
- **Explainable and interpretable** — the mechanisms and meaning of outputs can be understood by those overseeing or affected by the system.
- **Privacy-enhanced** — safeguards human autonomy, identity, and dignity through privacy-by-design and PETs.
- **Fair, with harmful bias managed** — addresses systemic, computational/statistical, and human-cognitive bias.

Valid & Reliable is treated as the necessary foundation for all other characteristics; Accountable & Transparent cuts across all of them.

The Four Core Functions

Function	Purpose
GOVERN	A cross-cutting function that cultivates a risk-management culture, sets accountability structures, policies, and processes, and is infused throughout the other three functions across the full AI lifecycle.
MAP	Establishes context — intended purpose, stakeholders, benefits, costs, and risks — to frame how an AI system's risks should be understood before design/development decisions are made.

Function	Purpose
MEASURE	Uses quantitative, qualitative, and mixed methods to analyze, benchmark, and monitor AI risks and trustworthy-AI characteristics identified in MAP.
MANAGE	Allocates resources to prioritized risks on a regular basis, treating (mitigating, transferring, avoiding, or accepting) risk and responding to incidents.

After GOVERN is instituted, most organizations proceed to MAP, then MEASURE and MANAGE — but the process is iterative and cross-referenced, not strictly linear.

How AI Risk Differs From Traditional Software Risk

- Training data can change/drift, affecting functionality and trustworthiness unpredictably.
- AI systems are inherently socio-technical — outcomes depend on human/societal context, not just code.
- Scale and complexity (billions of decision points) make failure modes hard to predict, especially for large pre-trained models.
- Increased opacity, reproducibility challenges, and underdeveloped software-testing standards versus traditional engineering.
- Elevated privacy risk from enhanced data-aggregation capability, and higher computational/environmental cost.

Total Control Count

Function	Categories	Subcategories (“Controls”)
GOVERN	6	19
MAP	5	18
MEASURE	4	22
MANAGE	4	13
Total	19	72

Full Control Listing — GOVERN Function

GOVERN cultivates a risk-management culture and establishes accountability, policy, and process across the AI lifecycle.

ID	Category / Name	Description
GOVERN 1.1	Legal & regulatory requirements	Legal and regulatory requirements involving AI are understood, managed, and documented.
GOVERN 1.2	Trustworthy AI characteristics integrated	The characteristics of trustworthy AI are integrated into organizational policies, processes, procedures, and practices.
GOVERN 1.3	Risk tolerance-based activities	Processes, procedures, and practices are in place to determine the needed level of risk management activities based on the organization's risk tolerance.
GOVERN 1.4	Transparent risk process	The risk management process and its outcomes are established through transparent policies, procedures, and other controls based on organizational risk priorities.
GOVERN 1.5	Monitoring & periodic review	Ongoing monitoring and periodic review of the risk management process and its outcomes are planned, with clearly defined roles/responsibilities and review frequency.
GOVERN 1.6	AI system inventory	Mechanisms are in place to inventory AI systems and are resourced according to organizational risk priorities.
GOVERN 1.7	Safe decommissioning	Processes and procedures are in place for decommissioning and phasing out AI systems safely and without increasing risk or decreasing trustworthiness.
GOVERN 2.1	Documented roles & communication	Roles, responsibilities, and lines of communication related to mapping, measuring, and managing AI risks are documented and clear throughout the organization.
GOVERN 2.2	AI risk management training	The organization's personnel and partners receive AI risk management training to perform their duties consistent with related policies and agreements.

ID	Category / Name	Description
GOVERN 2.3	Executive accountability	Executive leadership takes responsibility for decisions about risks associated with AI system development and deployment.
GOVERN 3.1	Diverse decision-making team	Decision-making related to mapping, measuring, and managing AI risks is informed by a diverse team (demographics, disciplines, experience, expertise, backgrounds).
GOVERN 3.2	Human-AI configuration policies	Policies and procedures define and differentiate roles/responsibilities for human-AI configurations and oversight of AI systems.
GOVERN 4.1	Safety-first culture	Organizational policies foster a critical-thinking, safety-first mindset in the design, development, deployment, and use of AI systems to minimize negative impacts.
GOVERN 4.2	Document & communicate impacts	Teams document the risks and potential impacts of the AI technology they design, develop, deploy, evaluate, and use, and communicate about impacts broadly.
GOVERN 4.3	Testing, incidents & info-sharing	Organizational practices enable AI testing, identification of incidents, and information sharing.
GOVERN 5.1	External feedback integration	Policies and practices collect, consider, prioritize, and integrate feedback from those external to the AI team on potential individual and societal impacts.
GOVERN 5.2	Regular feedback incorporation	Mechanisms enable the team that developed/deployed the AI system to regularly incorporate adjudicated feedback from relevant AI actors into design and implementation.
GOVERN 6.1	Third-party risk policy	Policies and procedures address AI risks from third-party entities, including risks of infringing a third party's IP or other rights.
GOVERN 6.2	Third-party contingency plans	Contingency processes are in place to handle failures or incidents in third-party data or AI systems deemed high-risk.

Full Control Listing — MAP Function

MAP establishes the context needed to frame risks related to a specific AI system, informing MEASURE and MANAGE.

ID	Category / Name	Description
MAP 1.1	Purpose & context documented	Intended purposes, beneficial uses, context-specific laws/norms, and deployment settings are understood and documented, including users, impacts, assumptions, and TEVV/system metrics.
MAP 1.2	Interdisciplinary participation	Interdisciplinary AI actors, competencies, skills, and capacities reflect demographic diversity and broad domain/user expertise; participation is documented.
MAP 1.3	Mission & goals understood	The organization's mission and relevant goals for AI technology are understood and documented.
MAP 1.4	Business value defined	The business value or context of business use has been clearly defined or re-evaluated for existing AI systems.
MAP 1.5	Risk tolerances documented	Organizational risk tolerances are determined and documented.
MAP 1.6	System requirements elicited	System requirements are elicited from and understood by relevant AI actors; design decisions account for socio-technical implications to address AI risks.
MAP 2.1	Tasks & methods defined	The specific tasks and methods used to implement the AI system's supported tasks are defined (e.g., classifiers, generative models, recommenders).
MAP 2.2	Knowledge limits documented	Information about the AI system's knowledge limits and how output may be used/overseen by humans is documented for decision support.
MAP 2.3	Scientific integrity & TEVV	Scientific integrity and TEVV considerations are identified and documented, including experimental design, data collection/selection, and construct validation.
MAP 3.1	Benefits examined	Potential benefits of intended AI system functionality and performance are examined and documented.

ID	Category / Name	Description
MAP 3.2	Costs examined	Potential costs, including non-monetary costs from expected/realized AI errors or functionality, are examined relative to organizational risk tolerance.
MAP 3.3	Application scope specified	Targeted application scope is specified and documented based on the system's capability, established context, and categorization.
MAP 3.4	Operator proficiency defined	Processes for operator/practitioner proficiency with AI system performance and trustworthiness, plus relevant standards/certifications, are defined and documented.
MAP 3.5	Human oversight defined	Processes for human oversight are defined, assessed, and documented in accordance with GOVERN function policies.
MAP 4.1	Component risk mapping	Approaches for mapping AI technology and legal risks of components — including third-party data/software and IP infringement risk — are in place and documented.
MAP 4.2	Internal risk controls	Internal risk controls for AI system components, including third-party AI technologies, are identified and documented.
MAP 5.1	Impact likelihood & magnitude	Likelihood and magnitude of each identified impact (beneficial and harmful) are identified and documented based on expected/past use, incident reports, and feedback.
MAP 5.2	Regular stakeholder engagement	Practices and personnel for regular engagement with relevant AI actors and integrating feedback on impacts are in place and documented.

Full Control Listing — MEASURE Function

MEASURE analyzes, benchmarks, and monitors AI risk and trustworthy-AI characteristics using quantitative, qualitative, or mixed methods.

ID	Category / Name	Description
MEASURE 1.1	Metrics selected by priority	Approaches and metrics for measuring risks identified in MAP are selected starting with the most significant risks; risks that cannot be measured are documented.
MEASURE 1.2	Metric/control appropriateness	Appropriateness of AI metrics and effectiveness of existing controls are regularly assessed and updated, including error reports and community impacts.
MEASURE 1.3	Independent assessment	Internal experts not serving as front-line developers, and/or independent assessors, are involved in regular assessments; external experts consulted as needed.
MEASURE 2.1	Test sets & tools documented	Test sets, metrics, and details about tools used during TEVV are documented.
MEASURE 2.2	Human-subject evaluations	Evaluations involving human subjects meet applicable requirements (including human-subject protection) and represent the relevant population.
MEASURE 2.3	Performance demonstrated	AI system performance/assurance criteria are measured and demonstrated for conditions similar to the deployment setting; measures are documented.
MEASURE 2.4	Production monitoring	The functionality and behavior of the AI system and its components are monitored when in production.
MEASURE 2.5	Validity & reliability demonstrated	The AI system to be deployed is demonstrated to be valid and reliable; limitations of generalizability beyond training conditions are documented.
MEASURE 2.6	Safety evaluated	The AI system is evaluated regularly for safety risk, demonstrated to be safe within risk tolerance, and able to fail safely; safety metrics cover reliability, monitoring, and response times.
MEASURE 2.7	Security & resilience evaluated	AI system security and resilience — as identified in MAP — are evaluated and documented.

ID	Category / Name	Description
MEASURE 2.8	Transparency & accountability	Risks associated with transparency and accountability are examined and documented.
MEASURE 2.9	Explained & validated	The AI model is explained, validated, and documented, and output is interpreted within context to inform responsible use and governance.
MEASURE 2.10	Privacy risk examined	Privacy risk of the AI system is examined and documented.
MEASURE 2.11	Fairness & bias evaluated	Fairness and bias, as identified in MAP, are evaluated and results documented.
MEASURE 2.12	Environmental impact assessed	Environmental impact and sustainability of AI model training and management activities are assessed and documented.
MEASURE 2.13	TEVV effectiveness evaluated	Effectiveness of the employed TEVV metrics and processes is evaluated and documented.
MEASURE 3.1	Risk tracking mechanisms	Approaches, personnel, and documentation regularly identify and track existing, unanticipated, and emergent AI risks based on deployed performance.
MEASURE 3.2	Hard-to-measure risk settings	Risk tracking approaches are considered for settings where AI risks are difficult to assess with current techniques or lack available metrics.
MEASURE 3.3	Feedback & appeal channels	Feedback processes for end users and impacted communities to report problems and appeal outcomes are established and integrated into evaluation metrics.
MEASURE 4.1	Deployment-context measurement	Measurement approaches for identifying AI risks are connected to deployment context(s) and informed by domain experts and end users; approaches are documented.
MEASURE 4.2	Trustworthiness validation	Measurement results on trustworthiness in deployment context(s) are informed by domain experts and AI actors to validate consistent performance; results documented.
MEASURE 4.3	Performance change tracking	Measurable performance improvements or declines, informed by consultations and field data, are identified and documented.

Full Control Listing — MANAGE Function

MANAGE allocates risk-treatment resources to prioritized, mapped, and measured risks on a regular basis.

ID	Category / Name	Description
MANAGE 1.1	Go/no-go determination	A determination is made as to whether the AI system achieves its intended purposes/objectives and whether development or deployment should proceed.
MANAGE 1.2	Risk treatment prioritized	Treatment of documented AI risks is prioritized based on impact, likelihood, and available resources or methods.
MANAGE 1.3	High-priority risk responses	Responses to high-priority AI risks (identified by MAP) are developed, planned, and documented; options include mitigating, transferring, avoiding, or accepting.
MANAGE 1.4	Residual risk documented	Negative residual risks (the sum of all unmitigated risks) to downstream acquirers and end users are documented.
MANAGE 2.1	Resource planning & alternatives	Resources required to manage AI risks are considered, along with viable non-AI alternatives, to reduce the magnitude or likelihood of potential impacts.
MANAGE 2.2	Sustaining deployed value	Mechanisms are in place and applied to sustain the value of deployed AI systems.
MANAGE 2.3	Unknown-risk response	Procedures are followed to respond to and recover from a previously unknown risk when it is identified.
MANAGE 2.4	Deactivation mechanisms	Mechanisms and assigned responsibilities are in place to supersede, disengage, or deactivate AI systems performing inconsistently with intended use.
MANAGE 3.1	Third-party risk monitoring	AI risks and benefits from third-party resources are regularly monitored, and risk controls are applied and documented.
MANAGE 3.2	Pre-trained model monitoring	Pre-trained models used for development are monitored as part of regular AI system monitoring and maintenance.

ID	Category / Name	Description
MANAGE 4.1	Post-deployment monitoring	Post-deployment monitoring plans are implemented, including capturing user/actor input, appeal and override, decommissioning, incident response, recovery, and change management.
MANAGE 4.2	Continual improvement	Measurable activities for continual improvement are integrated into AI system updates, including regular engagement with interested parties.
MANAGE 4.3	Incident communication	Incidents and errors are communicated to relevant AI actors, including affected communities; tracking, response, and recovery processes are followed and documented.



Applying the NIST AI RMF — RBI-Regulated NBFC (Low AI Security Maturity)

Scenario: Rather than build a bespoke governance framework, the NBFC decides to adopt the NIST AI RMF as its baseline operating model for both the credit-scoring model and the collections chatbot.

- **Start with GOVERN, not MAP:** Even with low maturity, stand up GOVERN 1.6 (an AI system inventory) and GOVERN 2.1 (documented roles) first — these are cheap, high-leverage controls that make every later function easier.
- **Use MAP to force an honest risk conversation:** MAP 1.1 and MAP 5.1 require documenting intended purpose and the likelihood/magnitude of harmful impacts — for the credit model, this means explicitly writing down 'wrongful loan denial to a creditworthy applicant' as a mapped risk, not leaving it implicit.
- **Treat MEASURE 2.11 (fairness/bias) as non-negotiable for credit scoring:** Given RBI's fair-lending expectations, bias testing across gender, geography, and income segments should be one of the first MEASURE controls implemented, even before more resource-intensive controls like MEASURE 2.12 (environmental impact).
- **Close the loop with MANAGE 4.1 and 4.3:** Implement a simple post-deployment monitoring plan and an incident-communication process now — these two controls alone would meaningfully close the gap between the NBFC's current low maturity and a defensible, audit-ready AI governance posture.